Davante

1

CIBERSEGURIDAD

Introducción a la ciberseguridad

ÍNDICE

1. Introducción y contextualización práctica 3

2. Factores clave y vulnerabilidades en un sistema informático 4

   2. 1. Factores clave 4

   2. 2. Vulnerabilidades en un sistema informático 5

3. Análisis de vulnerabilidades 5

4. Caso práctico 1: "Encriptar un pendrive con Windows 10" 7

5. Amenazas 8

   5. 1. Amenazas físicas 8

   5. 2. Amenazas lógicas 9

6. Valoración de los riesgos 10

   6. 1. Método cuantitativo 11

7. Método Mosler 12

8. Caso práctico 2: "Realizar una valoración de riesgos de adquirir un rúter de segunda mano" 14

9. Resumen y resolución del caso práctico de la unidad 15

10. Bibliografía 17

© Davante 978-84-10384-03-3

Reservados todos los derechos. Queda rigurosamente prohibida, sin la autorización escrita de los titulares del copyright, bajo las sanciones establecidas en las leyes, la reproducción, transmisión y distribución total o parcial de esta obra por cualquier medio o procedimiento, incluidos la reprografía y el tratamiento informático.

Objetivos

Valorar la importancia de la seguridad informática.

Conocer los factores claves de la seguridad.

Analizar las vulnerabilidades de un sistema informático.

Identificar los tipos de amenazas.

Valorar los riesgos de un sistema informático.

1. Introducción y contextualización práctica

En este capítulo se definen conceptos básicos para poder valorar la seguridad de un sistema informático y la pérdida económica que conlleva un sistema si deja de funcionar.

¿Qué ocurriría si el sistema de uno de estos servicios dejase de funcionar?

- Cuentas bancarias.
- Comercio internacional.
- Plantas de energía eléctrica.
- Ejército.
- Satélites.
- Sistema judicial.
- Sistema sanitario (historial de pacientes, telemedicina).

Se produciría un desastre asociado a un fallo informático con graves consecuencias económicas.

La **protección** de los sistemas y las redes de computadoras es **crítica** y se deben adoptar **medidas preventivas** que permitan adelantarse al atacante.

A continuación, vamos a plantear un caso práctico a través del cual podremos aproximarnos de forma práctica a la teoría de este tema.

Escucha el siguiente audio donde planteamos la contextualización práctica de este tema. Encontrarás su resolución en el apartado 'Resumen y resolución del caso práctico'.



Fig.1. Prensa, películas y noticias sobre ataques.

Audio Intro. "*Amenazas de ciberseguridad existentes en la actualidad para una empresa*"

https://bit.ly/43c8lFc

2. Factores clave y vulnerabilidades en un sistema informático

2. 1. Factores clave

Un modelo a seguir como política de seguridad de la información es la tríada CIA (***Confidentiality, Integrity and Availability***). Constituyen los tres pilares de la seguridad de la información, y será más fiable si se garantizan dichos aspectos.



Fig.2. Triada CID (confidencialidad, integridad y disponibilidad).

- **Fiabilidad**: Se define como la probabilidad de que un sistema se comporte como se esperaba de él. En términos absolutos, es imposible que un sistema sea seguro al 100% y, por tanto, se determina el porcentaje de fiabilidad del sistema.
- **Confidencialidad**: Es la propiedad de prevenir la divulgación de la información a personas o sistemas no autorizados, también conocida como confiabilidad.
- **Integridad**: Es la propiedad que busca mantener los datos libres de modificaciones no autorizadas.
- **Disponibilidad**: Es la característica, cualidad o condición de la información de encontrarse a disposición de quienes deben acceder a ella, ya sean personas, procesos o aplicaciones.

2. 2. Vulnerabilidades en un sistema informático

Son las brechas de seguridad que permiten acceder a un sistema informático y a sus recursos, pudiendo ser intencionada o no. Entre los recursos a los que se puede acceder se encuentran:

- **Hardware**: Elementos físicos del sistema, como procesadores, sistemas de almacenamiento, etc.
- **Software**: Aplicaciones que se ejecutan en el hardware, incluyendo los sistemas operativos.
- **Datos**: Comprende toda la información que viaja por la red y el acceso a las bases de datos.

El activo más crítico son los datos y para protegerlos se utiliza la **encriptación**, junto a una política de copias de seguridad para ser capaces de reponerlos en el menor tiempo posible.

Investigamos...

Investiga el término Ransomware, que tipo de ataque es, su funcionamiento, cuando comenzó, como se identifica y las consecuencias que tiene.

3. Análisis de vulnerabilidades

Según los elementos vulnerables de un sistema, se pueden encontrar las siguientes **vulnerabilidades**:

En el hardware:

- Forma intencionada: Rotura del cable.
- Forma fortuita: Incendio, rotura del cable.
- Tiempo de vida útil del hardware (TTL): Descuido y mal uso.
- Suministro de energía.
- Inundación.
- Robo físico.

En el software:

- Errores de programación.
- Exposición a datos sensibles.
- Fallos de control de acceso.
- Malas configuraciones.

En los datos:

- Protocolos de red para transmitir información.
- Falta de sensibilización de los usuarios y responsables del sistema.
- Limitación de tecnologías de seguridad.
- Disponibilidad.

Todos los elementos vulnerables (hardware, software y datos) de nuestro sistema de información se pueden producir por los siguientes factores:

A. Medios naturales.

B. Medios de almacenamiento.

C. Transmisión de la información (medios de comunicación).

D. Factores humanos.

E. Factores físicos.

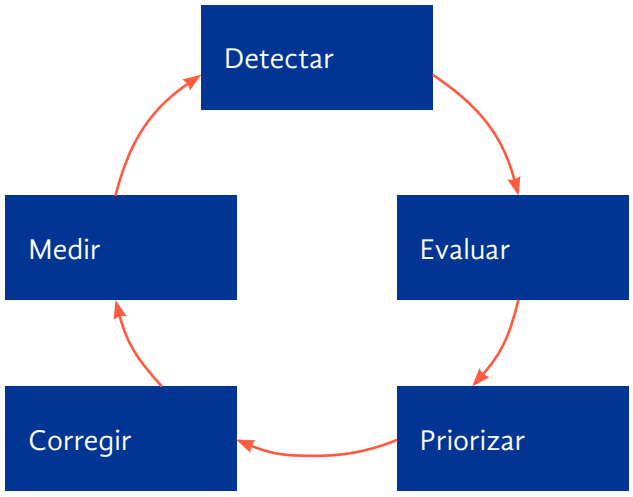


Fig.3. Análisis de vulnerabilidades.

A continuación un audio sobre el ransomware y qué repercusiones ha causado:

Audio 1. *"¿Qué es el ransomware y qué repercusiones ha causado?"*

https://bit.ly/43gK4Om

4. Caso práctico 1: "Encriptar un pendrive con Windows 10"

Planteamiento: Tienes información confidencial y decides guardarla en un pendrive al que no quieres que nadie tenga acceso, salvo tú mismo.

Nudo: Accede a la página oficial de Microsoft y analiza cada paso que se debe realizar y si nuestro equipo lo puede hacer.

Desenlace: Microsoft tiene la herramienta de **BitLocker** para cifrar de forma gratuita los datos guardados en un pendrive. Se puede aplicar desde Windows 7 y, actualmente, se encuentra incluida en los sistemas operativos Windows 10, Windows 11 y Windows Server 2016 y superiores.

Requiere tener un hardware con un equipo TPM 1.2 o versiones posteriores, que deberá contener un firmware de la BIOS.

En Windows 10 Profesional se comienza buscando la herramienta **BitLocker** y se abre. Aparecen las unidades que contiene el sistema y se selecciona la unidad deseada con la acción de activar BitLocker.

Nos pedirá la contraseña para desbloquear la unidad y la escribimos, una que solo conozcamos nosotros.

Nos pedirá dónde guardar una copia de seguridad de la clave de recuperación, bien imprimirla, guardarla en un archivo o en la nube.

Comenzará el proceso que tardará un tiempo largo y ya tendremos encriptado nuestro pendrive.

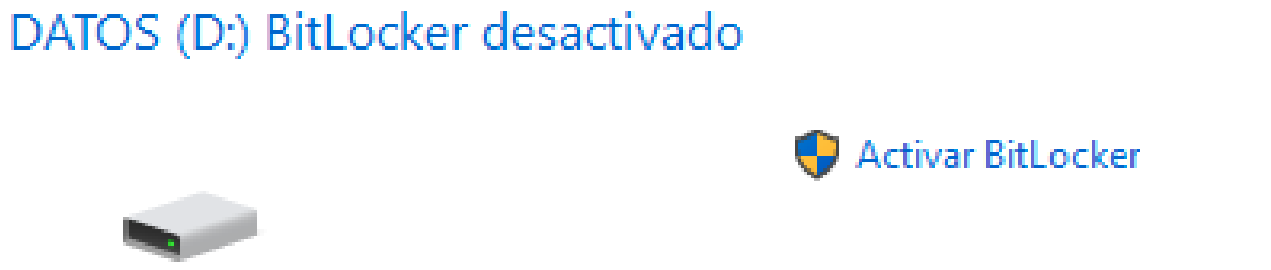


Fig.4. Selección de unidad.

5. Amenazas

Es una **advertencia o factor que causa un daño al sistema informático** (hardware y software) **y altera la CIA**. Cualquier acción que aproveche una vulnerabilidad para atentar contra la seguridad de un sistema constituye una amenaza.

Pueden ser internas o externas, según su procedencia, y también se pueden clasificar en lógicas o físicas. Veamos algún **ejemplo** de amenazas:

- Ataques: Fraudes, robos, virus, etc.
- Sucesos físicos: Incendios, inundaciones, huracanes, etc.
- Negligencia.
- Decisiones institucionales.



Fig.5. Riesgo de una organización.

Investigamos...

Investiga las diferencias entre vulnerabilidad y amenaza, busca posibles ejemplos, y cómo puede afectar al software informático de una organización.

5. 1. Amenazas físicas

Este tipo de amenazas no suelen cambiar y se pueden clasificar en cuatro tipos:

- **Acceso físico a la información**: Cualquiera que pueda acceder a un recurso físico pone en riesgo la seguridad sobre el mismo. Una toma de conexión a una red informática no controlada supone una vía de acceso libre para un atacante.
- **Desastres naturales**: Cualquier desastre natural puede impedir un acceso totalmente anegado.



Fig.6. Equipo incendiado.

- **Señales electromagnéticas**: Toda señal que retransmite información de forma inalámbrica puede ser factible de ser capturada. Ejemplos: TPV inalámbricos, teclados y ratones inalámbricos, redes wifi, etc.

- **Averías del hardware**: Picos de sobretensión, altas temperaturas, fallos en la alimentación, etc., pueden llegar a dejar los servidores y los servicios que ofrece caídos. No llegan a ser desastres naturales, pues se pueden evitar. Un ejemplo sería un servidor que se apaga porque el procesador alcanza una temperatura elevada.

5. 2. Amenazas lógicas

Comprenden un conjunto de **programas capaces de dañar el sistema informático**, bien de forma intencionada o por error:

- **Forma intencionada**: Malware.

- **Por error**: Bugs o agujeros de seguridad.

Existen muchas amenazas de este tipo, aumentando cada año. Algunas que se pueden encontrar son:

1. **Virus**: Es un archivo ejecutable; al ejecutarse, el virus entra en acción y es capaz de ejecutarse en otros programas.

2. **Gusanos**: Programa capaz de ejecutarse y propagarse por sí mismo a través de las redes, pudiendo contener virus ocultos. Suelen aprovechar bugs que tiene un sistema.

3. **Software erróneo**: Son los errores de programación en la creación de un programa, capaz de atacar al sistema y crear un *exploit*.

4. **Exploits**: Es una vulnerabilidad del sistema operativo y la red en que se encuentran que aprovecha un programa para poder atacar.

5. **Puertas traseras**: Son atajos para que los programadores puedan acceder a una aplicación y detectar fallos. Si no son destruidas cuando la aplicación ha finalizado, constituye una puerta abierta a la seguridad.

6. **Bombas lógicas**: Se activan cuando se cumple una condición y su objetivo es diferente al programa creado.

7. **Caballos de Troya**: Es un simulador que simula diferentes tareas, pero en realidad es un atacante oculto para evitar ser descubierto.

8. **Spyware**: Son programas o sistemas espía cuyo objetivo es recopilar información para ser vendida posteriormente. Un ejemplo es la obtención de contraseñas, cuentas bancarias, números de teléfonos, direcciones, etc.

9. **Adware**: Programas que abren ventanas emergentes y muestran publicidad de productos y servicios. Su objetivo es subvencionar el uso de la aplicación o recurso. Un ejemplo muy conocido es YouTube.

10. **Spoofing**: Consiste en implantar la identidad con fines delictivos.

11. **Phishing**: Su objetivo es conseguir de forma fraudulenta contraseñas de los usuarios cuando acceden a diferentes medios para suplantar la identidad. Un ejemplo muy concurrido es el acceso a los bancos por medio de enlaces falsos.



Fig.7. Phishing.

12. **Spam**: Conocido como correo basura, consiste en la recepción de mensajes no solicitados tanto en buzones de correo como en dispositivos móviles.

Investigamos...

Existen múltiples tipos de ciberataques que se van actualizando con el paso del tiempo, o desaparecen. Investiga los ataques más conocidos: DoS, Ingeniería Social y Man-in-the-middle.

6. Valoración de los riesgos

Es un importante paso que se debe realizar, cuyo fin es **evitar los posibles incidentes e implementar las medidas de seguridad** adecuadas. Algunos incidentes pueden implicar problemas legales que pueden suponer sanciones económicas y daños a la reputación e imagen de la empresa.

Consiste en analizar y evaluar los riesgos que tiene una organización en caso de sufrir un ataque informático. Estos riesgos no solo están destinados a los equipos informáticos, sino también a otros activos, como las personas, las operaciones financieras y los datos.

Si una organización no efectúa este tipo de análisis, estaría expuesta a un alto nivel de riesgo y a sufrir ciberataques que impidan el uso de sus sistemas informáticos.

6. 1. Método cuantitativo

La evaluación de riesgos se basa en un proceso estructurado que consta de tres pasos:

1. **Identificar activos**.
2. **Análisis de dichos activos**.
3. **Priorizar los riesgos de cada activo**.

La fórmula a aplicar para valorar el riesgo que conlleva una supuesta amenaza es:

Riesgo = Probabilidad de amenaza * Magnitud de daño

Realicemos un análisis de un edificio en Madrid:

Activo	Amenaza	Riesgo
Edificio	Caiga un rayo	1%

Tabla.1. Análisis de edificio.

Los valores que se dan en el riesgo vienen determinados por la magnitud del daño y la probabilidad de amenaza, pudiendo obtener un riesgo bajo, medio o alto.

La magnitud en caso de que caiga un rayo es alta, pero la probabilidad de que ocurra es mínima, obteniendo un resultado de 4.

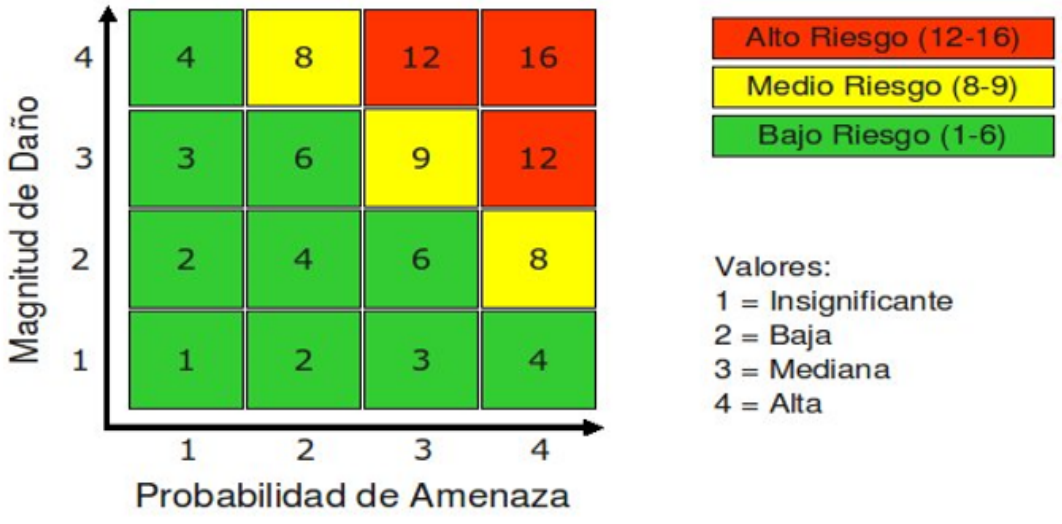


Fig.8. Cálculo de riesgos.

7. Método Mosler

Es un método cuantitativo aplicable a cualquier organización que consta de cuatro fases:

1. **Definición del riesgo**: Activo y daño si se hurta.
2. **Análisis del riesgo**: Identificación de variables F, S, P, E, A y V.
3. **Evolución del riesgo**: Cálculo del carácter de riesgo.
4. **Cálculo de la clase de riesgo**: Muy bajo, pequeño, normal, grande y elevado.

La identificación de cada variable corresponde con los siguientes conceptos, cuya escala va con valores numéricos del 1 al 5:

F: Criterios de función: Las consecuencias negativas o los daños pueden alterar o afectar de forma diferente la actividad.

• Muy gravemente	5
• Gravemente	4
• Medianamente	3
• Levemente	2
• Muy levemente	1

S: Criterios de sustitución: Dificultad para ser sustituidos los bienes o productos. Escalas:

• Muy difícilmente	5
• Difícilmente	4
• Sin muchas dificultades	3
• Fácilmente	2
• Muy fácilmente	1

P: Criterios de profundidad: Perturbación y efectos psicológicos que podrían producirse en la imagen:

• Perturbaciones muy graves	5
• Perturbaciones graves	4
• Perturbaciones limitadas	3
• Perturbaciones leves	2
• Perturbaciones muy leves	1

E: Criterios de extensión: El alcance de los daños o las pérdidas a nivel territorial.

• Alcance internacional	5
• Carácter nacional	4
• Carácter regional	3
• Carácter local	2
• Carácter individual	1

A: Criterios de agresión: La probabilidad de que el riesgo se manifieste.

• Muy alta	5
• Alta	4
• Normal	3
• Baja	2
• Muy baja	1

V: Criterios de vulnerabilidad: Probabilidad de que realmente se produzcan daños o pérdidas.

Se aplican las siguientes fórmulas y se obtendría un nivel de riesgo según el valor de C en la figura 8:

- Importancia del suceso **I = F x S.**
- Daños ocasionados **D = P x E.**
- Carácter de riesgo **C = I + D.**

Puntaje	Riesgo
Entre 1 y 250	Riesgo muy bajo
251 y 500	Riesgo bajo
501 y 750	Riesgo normal
751 y 1.000	Riesgo elevado
1.001 y 1.250	Riesgo muy elevado

Tabla.2. Valores de riesgo.

A continuación un vídeo sobre análisis de riesgos:

Vídeo 1. "*Análisis de riesgos*"

https://bit.ly/3MKpGxZ

8. Caso práctico 2: "Realizar una valoración de riesgos de adquirir un rúter de segunda mano"

Planteamiento: El propietario quiere valorar si conviene o no adquirir rúteres de segunda mano a un precio mucho más económico.

Nudo: Se aplica el método Mosler para valorar cada nivel de riesgo encontrado, valorando sus variables F, S, P, E, A y V. Por último, se hacen los cálculos para obtener el carácter de riesgo.

Desenlace: El primer paso será analizar los posibles riesgos que supone comprar un producto de segunda mano y el último paso será valorar dichos riesgos aplicando el método Mosler.

Los riesgos que se han encontrado serían:

- Falta de un manual adecuado.
- Fallos ocultos.
- Puede contener malware.
- Producto no llega.

El análisis de cada riesgo, mediante una valoración subjetiva, sería el siguiente:

Riesgos	F	S	P	E	A	V
Falta de un manual adecuado	3	2	4	2	4	2
Fallos ocultos	4	4	3	2	4	3
Puede contener malware	4	4	5	2	4	5
Producto no llega	5	4	4	2	4	5

Tabla.3. Obtención de variables.

El siguiente paso será realizar los cálculos del método Mosler para obtener los valores de I, D, C, PR y ER.

Riesgos	I = F x S	D = P x E	C = I + D	PR = A x V	ER = C x PR
Falta de un manual adecuado	6	8	14	8	112
Fallos ocultos	16	6	22	13	286
Puede contener malware	16	10	26	20	520
Producto no llega	20	8	28	20	560

Tabla.4. Cálculo de fórmulas.

Por último, según el valor obtenido y aplicando los niveles de la tabla, se obtendrían las siguientes valoraciones:

Riesgos	Nivel de riesgo
Falta de un manual adecuado	Muy bajo
Fallos ocultos	Pequeño
Puede contener malware	Normal
Producto no llega	Normal

Tabla.5. Obtención de niveles de riesgo.

9. Resumen y resolución del caso práctico de la unidad

Este tema introduce la ciberseguridad destacando su importancia ante la creciente dependencia de los sistemas informáticos en sectores críticos, como la banca, la energía o la sanidad, y, a continuación, se definen conceptos clave, como seguridad, vulnerabilidad, amenaza y riesgo, enfatizando la necesidad de medidas preventivas para proteger la información.

Se explican los factores clave de la seguridad informática a través de la tríada CIA: confidencialidad, integridad y disponibilidad. También se aborda la fiabilidad del sistema y la importancia de mantener los datos seguros mediante técnicas como la encriptación y políticas de respaldo.

Las vulnerabilidades pueden afectar al hardware, software o datos, y originarse por errores, fallos técnicos o factores externos, como desastres naturales o descuidos humanos. Estas debilidades pueden ser aprovechadas por amenazas que alteran el funcionamiento de los sistemas.

Las amenazas se clasifican en físicas (como incendios o accesos no autorizados) y lógicas (como virus, malware, spyware o phishing). Para mitigar los riesgos, se aplican métodos de análisis cuantitativo que permiten evaluar la probabilidad y el impacto de incidentes, y priorizar la seguridad de los activos.

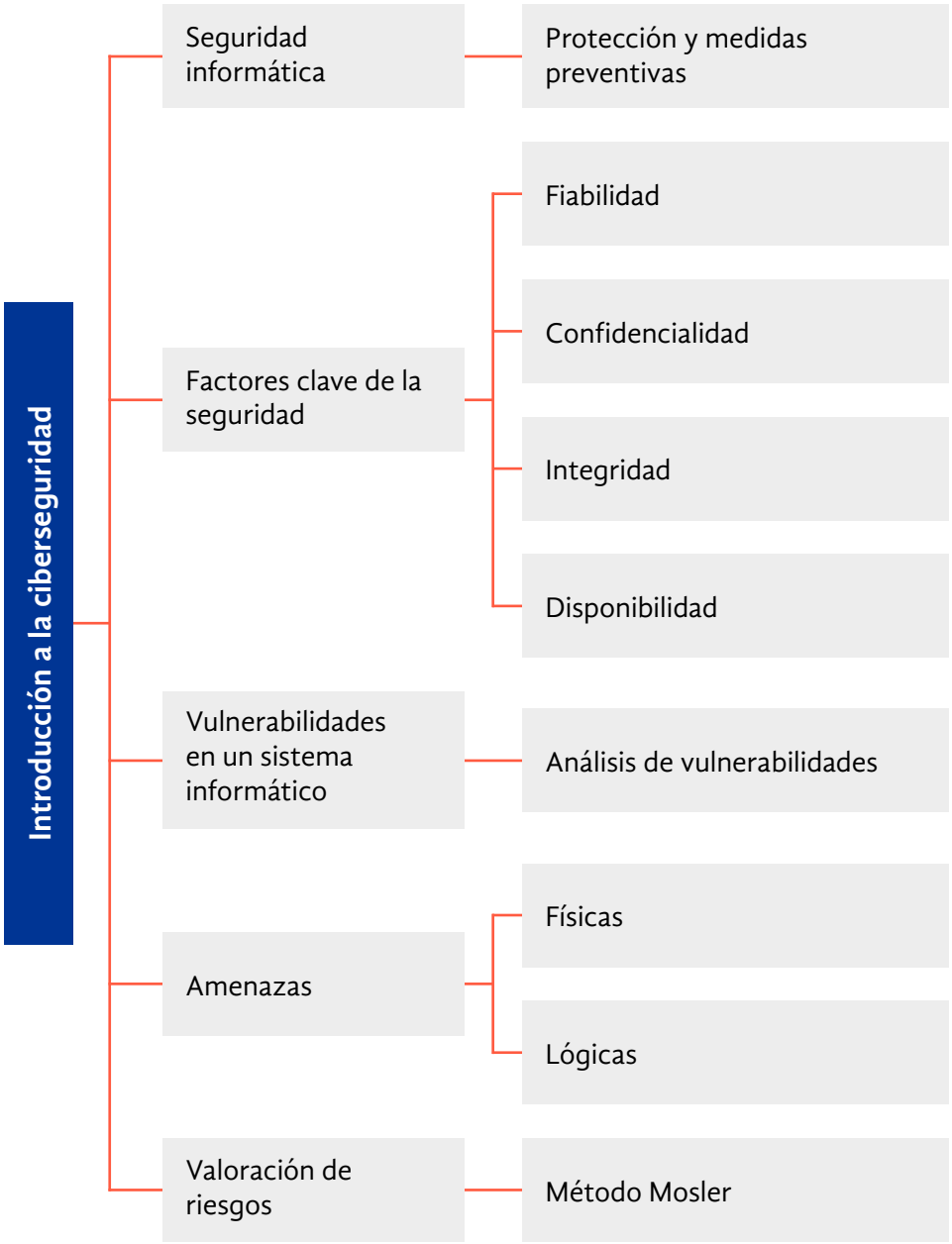


Fig.9. Esquema resumen del tema.

Resolución del caso práctico de la unidad

Para el desarrollo del caso práctico se aplica el método Mosler, analizando todos los posibles riesgos para realizar una tabla valorando de 1 a 5 la posibilidad de que ocurra dicho riesgo y las consecuencias que tiene para la organización.

Para conocer los posibles riesgos de un caso práctico, es conveniente estar dado de alta en canales de noticias de seguridad informática y poder estar actualizado de todos los cibercrímenes que se cometen y sus posibles repercusiones económicas para poder hacer una valoración cuantitativa y calcular dicho riesgo. Ejemplos de canales de noticias: Hispasec, NS, Incibe, etc.

10. Bibliografía

Deane, A., and Kraus, A. (2021). *The official CISSP CBK Reference (6th Edicion)*. Sybex Inc., U.S.

Kevin, M. (2021). *Seguridad de las Redes Informáticas para Principiantes*. Computer Publishing.

Cot, E. (2016). *Constelación Babieca*. UOC Universat Oberta de Cataluña.

Chris, M. (2008). *Seguridad de redes*. Anaya Multimedia.